Botium Toys Security Audit

Educational Scenario Assessment

Based on the Botium Toys scenario provided as part of

the Google Cybersecurity Certificate training activity.

# Controls and compliance checklist

To complete the controls assessment checklist, I refered to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, I refered to the control categories document.

**Controls assessment checklist**

| Yes | No | Control | Explanation |
|---|---|---|---|
| ☐ | ☑ | Least Privilege | (All employees have access to stored data even to PII & SPI) |
| ☐ | ☑ | Disaster recovery plans | (Currently No recovery plan, no Backups) |
| ☑ | ☐ | Password policies | (Password policy exist although nominal & need improvement) |
| ☐ | ☑ | Separation of duties | (No separation of duties, need role based access) |
| ☑ | ☐ | Firewall | (Firewall system exists) |
| ☐ | ☑ | Intrusion detection system (IDS) | (Need IDS system to detect intrusions) |

| | | | |
|---|---|---|---|
| ☐ | ☑ | Backups | (Need backups for disaster recovery) |
| ☑ | ☐ | Antivirus software | (Installed & monitored regularly) |
| ☑ | ☐ | Manual monitoring, maintenance, and intervention for legacy systems | |
| ☐ | ☑ | Encryption | (Create confidentiality but Encryption is not currently used. ) |
| ☐ | ☑ | Password management system | (Currently do not have a password management system ) |
| ☑ | ☐ | Locks (offices, storefront, warehouse) | (Create physical security have sufficient locks) |
| ☑ | ☐ | Closed-circuit television (CCTV) surveillance | (Each store have CCTV) |
| ☑ | ☐ | Fire detection/prevention (fire alarm, sprinkler system, etc.) | |

---

To complete the compliance checklist,I  refered to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation,I  reviewed the controls, frameworks, and compliance reading.

**Compliance checklist**

Payment Card Industry Data Security Standard (PCI DSS)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | Only authorized users have access to customers' credit card Information.<br>**Explanation**: All employees have access to PII or SPI & can access cardholders data. |

| | | |
|---|---|---|
| ☐ | ☑ | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.<br>**Explanation:** Appropriate access is missing & information is not encrypted. |
| ☐ | ☑ | Implement data encryption procedures to better secure credit card transaction touchpoints and data.<br>**Explanation:**Encryption is not currently used. |
| ☐ | ☑ | Adopt secure password management policies.<br>**Explanation:**Password policy exists but is weak & their is no proper management. |

General Data Protection Regulation (GDPR)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | E.U. customers' data is kept private/secured.<br>**Explanation:**Encryption & least privileged is missing. |
| ☑ | ☐ | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.<br>**Explanation:**A plan exists. |
| ☐ | ☑ | Ensure data is properly classified and inventoried.<br>**Explanation:**No proper data & access management exists. |
| ☑ | ☐ | Enforce privacy policies, procedures, and processes to properly document and maintain data.<br>**Explanation:**Yes they do. |

System and Organizations Controls (SOC type 1, SOC type 2)

| Yes | No | Best practice |
|---|---|---|
| ☐ | ☑ | User access policies are established. |

**Explanation:**Least privileged and user access policies does not exists .

| | | |
|---|---|---|
| ☐ | ☑ | Sensitive data (PII/SPII) is confidential/private.<br>**Explanation:**No role based access and encryption is missing. |
| ☑ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated.<br>**Explanation:**Yes report state that data integrity is ensured. |
| ☑ | ☐ | Data is available to individuals authorized to access it.<br>**Explanation:**IT department ensures availability. |

---